

USF AI COLLABORATIVE · INAUGURAL MEETING

AI Governance at an Academic Medical Center

Development, implementation, and monitoring

Mason Pearce, MD

General Surgery · Clinical Informatics Fellow

University of South Florida

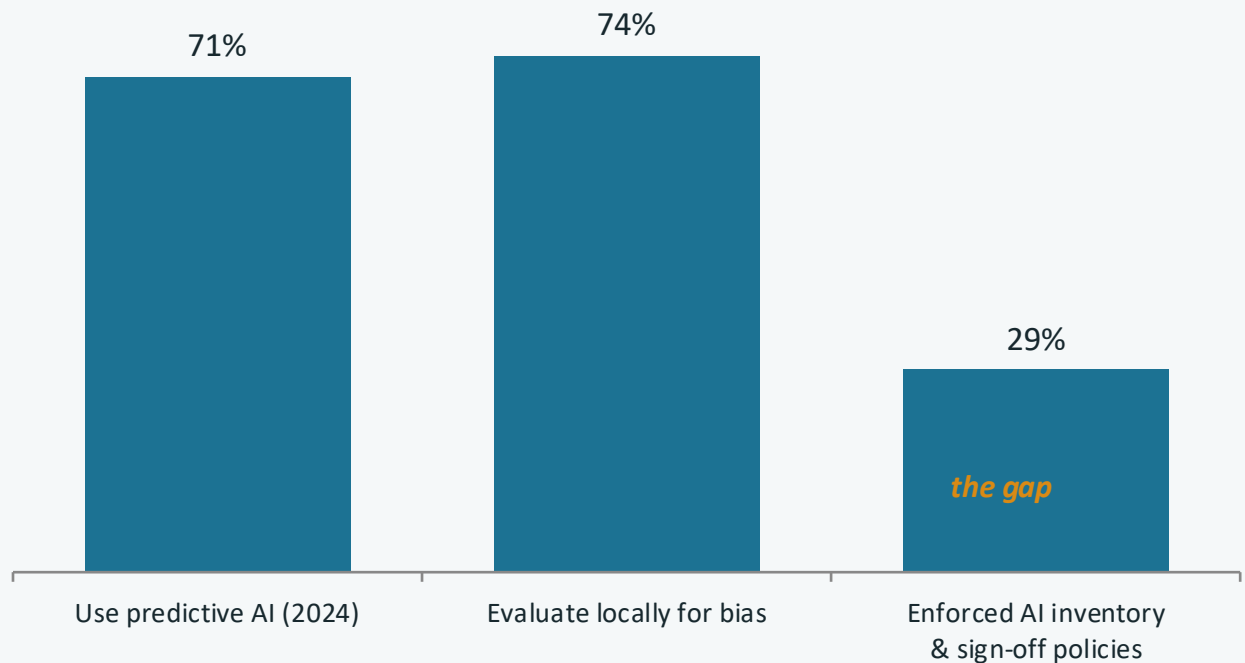


Have you personally used an AI tool at work that no one formally approved?

WHY THIS MATTERS

Adoption is outrunning oversight

Adoption figures are the latest federal survey (collected 2024); governance figures are current to late 2025.



+\$670,000

added to the average data-breach cost when employees use unapproved “shadow AI” tools



63%

of organizations have no AI governance policy or still writing one; of those breached through AI, 97% lacked basic AI access controls.

Sources: AHA IT Supplement / ASTP Data Brief, 2023–24; IBM Cost of a Data Breach 2025; Black Book Research, Oct–Nov 2025 (n=182).

You can't govern what you can't see

Before any framework, two blind spots make the real problem invisible:



Shadow AI

Team members adopt public AI tools with no IT knowledge or approval. Frontline example: Doximity GPT for patient letters and notes. You cannot inventory what no one told you about.



Silent vendor updates

AI is quietly switched on inside tools you already own (EHR, ambient scribe, imaging). A vendor can change the model overnight and never tell you the behavior changed.

Shadow AI as a top breach factor: IBM Cost of a Data Breach 2025.

Stand on the standards, don't reinvent them

The framework operationalizes existing national and international guidance rather than starting from a blank page.

● **NIST AI RMF 1.0**

Govern · Map · Measure ·
Manage

● **HHS AI Strategy**

Five pillars (Sept 2025)

● **CHAI**

Applied model card schema

● **FDA AI/ML**

GMLP · predetermined change
control

● **OMB M-25-21 / 22**

High-impact AI · acquisition

● **Joint Commission +
CHAI**

Responsible Use of AI, Sept
2025

● **ONC HTI-1**

Algorithm transparency

● **EU AI Act**

Risk-tiered obligations

Alignment is the credibility argument: every requirement traces to a recognized standard.

One tool, five lenses: the Five-Domain model



Security

Data sensitivity, PHI exposure, access controls



Utility & Validity

Does it work, and does it help the workflow?



Compliance / Risk

FDA status, regulation, liability exposure



Ethics

Bias, fairness, equity across subgroups



Educational Impact

Effect on trainees and skill development

Educational Impact is the academic-medical-center difference. Industry frameworks stop at safety and bias. A teaching hospital also has to ask what a tool does to how trainees learn.

Three distinct failure modes

“Reliance on AI during the early, formative years of clinical training may prevent trainees from ever developing the foundational reasoning that safe, independent practice requires.” **Ke et al., Nature Medicine 2026**

Deskilling

EXPERIENCED CLINICIANS

A clinician who already had the skill gradually loses it through reliance on automation. The foundational architecture stays intact.

Never-skilling

NEW

TRAINEES · THE NEW IDEA

A trainee never builds the skill at all, because AI substituted for the cognitive effort before the skill could form.

Mis-skilling

TRAINEES & CLINICIANS

A trainee uncritically adopts erroneous or biased AI output and internalizes flawed reasoning patterns as fact.

28% → 22%

Real signal, not theory: after three months of AI-assisted colonoscopy, endoscopists’ unassisted adenoma detection rate fell six points. When the AI came off, the skill had quietly eroded.

Turning risk into a tier

The five domains tell you what to look at. Scoring turns those judgments into a tier and a review path.

1 • Inherent risk (what kind of AI is it?)

A	Static / non-adaptive	Predictive ML, NLP, rules	Tier 1
B	Generative / probabilistic	LLMs, RAG, generative AI	Tier 2
C	Decision-influencing	CDS, recommendation engines	Tier 3
D	Adaptive / autonomous	Agentic, continuous learning	Tier 4

2 • Contextual risk (how is it used here?)

Six domains scored 1–4

Clinical impact · Data sensitivity · Population scope · Reversibility ·
Regulatory status · Model transparency

Final Tier = MAX(base tier, score-adjusted tier)

A single high-risk domain can't hide inside a good average.

Routing: any domain = 4 → Full review. Highest 2–3 → Expedited. All 1s → Exempt.

A multidisciplinary committee, by design



Executive sponsor

CMIO / CIO, final call on Tier 4



Clinical informatics

Workflow fit, physician champions



Data science

Validation, performance, drift



IT security (CISO)

Cyber review, shadow-AI monitoring



Privacy / compliance

HIPAA, regulatory, audit readiness



Legal / contracts

Liability, IP, data rights



Quality / patient safety

Adverse-event and safety escalation

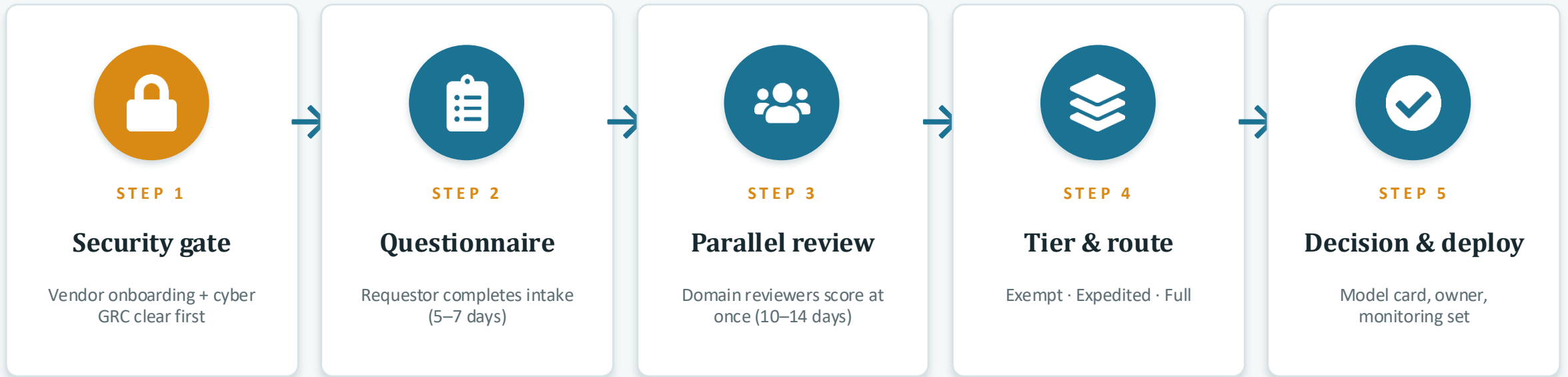


Education / GME voice

Trainee and learning impact

Cadence: Full committee monthly · Technical subcommittee bi-weekly · Expedited panel in 48–72 hours

One front door for every AI request



Review timelines by tier: Tier 1 in 5–7 days · Tier 2 in 14–21 days · Tier 3 in 30–45 days · Tier 4 in 60–90 days (+ C-suite/board notification)

Intake tooling shown generically; example implementation uses ServiceNow / NTracts for onboarding.

Model cards: a nutrition label for every tool

One standardized card per tool, CHAI-aligned and stored centrally (example: Palantir Foundry registry).



Identification

Name, version, vendor, owner, FDA status



Intended use

Population, users, setting, out-of-scope uses



Architecture & data

Model type, inputs, training data, update mechanism



Performance

AUROC, sensitivity, subgroup results, local validation



Bias & limits

Known disparities, failure modes, mitigations



Governance

Owner, review dates, monitoring link, incidents

Who owns it: the AI governance program holds the card and the central registry as the single source of truth. Security, data science, and legal each fill their section.

Two problems that break most programs



Finding shadow AI

- Network sweep via existing security stack (e.g., Zscaler, Palo Alto, Netskope) + CASB / DLP
- AI attestation letters to top vendors by spend
- Offer approved alternatives so people stop going rogue

Lesson: it is harder than you think. Many vendors sell discovery, so find what actually fits your stack.



Catching silent updates

- Contractual material-change clause: 30-day notice (48h for critical)
- Define “substantial change” (e.g., >5% AUROC shift, new base model)
- API “fingerprinting” probes for high-stakes LLMs

Lesson: put the burden on the vendor in writing before go-live, not after an incident.

Independent programs are converging



Duke • ABCDS

Lifecycle governance of algorithm-based clinical decision support; five pillars, pre- and post-deployment checkpoints.



Stanford • RAISE-Health

Stanford Medicine + HAI initiative for responsible AI in research, education, and care.



Mayo Clinic

Published comprehensive approach to responsible AI development and deployment (2025).



Joint Commission + CHAI

Responsible Use of AI in Healthcare guidance, Sept 2025: governance, monitoring, safety reporting.

They converge on the same pillars: a multidisciplinary committee, lifecycle governance, model cards, local validation, and continuous monitoring. This framework adds the education lens.

Oversight scales with risk

Tier 4	Critical: autonomous, life-safety	Continuous + weekly human audit
Tier 3	High: informs clinical decisions	Daily automated + monthly audit
Tier 2	Moderate: workflow, admin PHI	Weekly + quarterly audit
Tier 1	Low: no patient data	Automated monitoring only

Non-compliance ladder

+14 days
Department head notified

+30 days
Marked non-compliant, feature freeze

+60 days
Tool suspended

Some reviews can't wait for the schedule

Trigger-based reviews

- **Patient-safety event** Emergency full-committee review, 24–48h
- **Performance drift** Technical subcommittee, 5 business days
- **Vendor model update** Technical review per contract terms
- **FDA regulatory action** Full committee + legal, immediate
- **Security incident** Per incident-response plan

Automate the tracking, reserve human judgment

- Machine handles**
Metric tracking · drift detection · threshold alerts · review-calendar reminders · dashboard status
- **People decide**
Risk-tier classification · clinical-impact judgment · whether an alert means stop, retrain, or retire the tool.

Centralized dashboard example: Palantir Foundry governance workspace.

Lessons from building it



Executive buy-in is mandatory

Without it, governance has no authority and no budget. Start at the top.



Your CISO is your best ally

Frame it as hard-dollar risk. Security understands the exposure and will help you make the case.



Budget for people

You will likely need new FTEs. Be ready to explain to leaders why this work cannot be a side-of-desk task.



Two jobs at once

You are cleaning up the current state while a swarm of new requests arrives. Plan for separate teams.



Stay close to the frontline

Clinicians will tell you what is actually in use (Doximity keeps coming up) long before IT sees it.



Teach the why

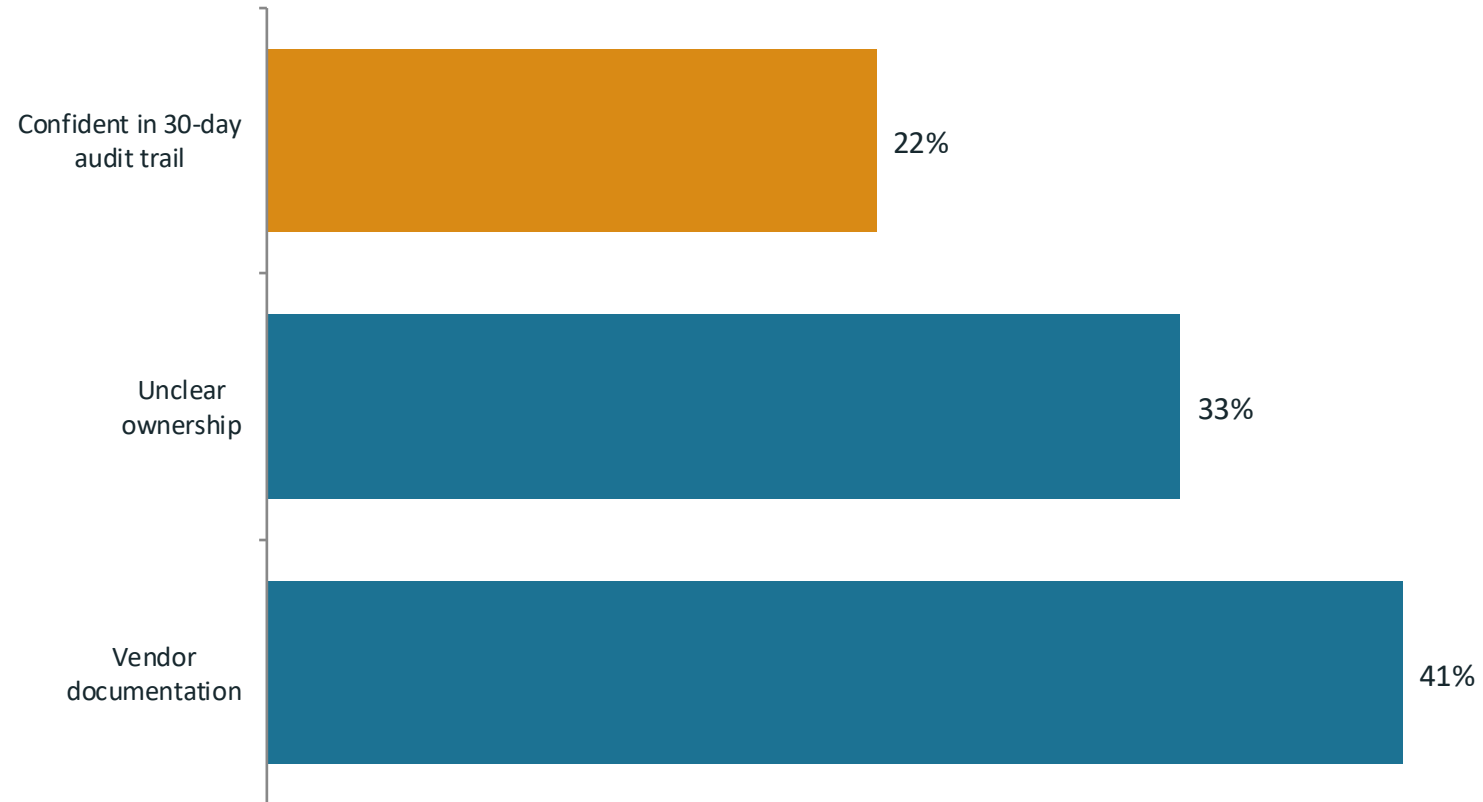
Trainees and staff follow governance when they understand the risk, not because a policy told them to.



What's the #1 barrier to doing AI governance well?

What's the #1 barrier to doing AI governance well?

The national picture



Source: Black Book Research survey of 182 hospital leaders, Oct–Nov 2025.

Some things still don't have answers



Wearables and the edge of policy

AI glasses (e.g., Meta) can record and reason in real time.
Can a hospital tell staff they can't wear a personal device?
How do we even monitor personal items on the floor?

Open questions for the room

- Where does institutional governance end and personal-device policy begin?
- What is the best way to introduce AI tools into medical education?
- How do you govern AI that gets smarter after go-live?
- What does “informed consent” mean when AI is ambient?

How any AMC can start

1



Start with visibility

Run one network sweep and send vendor attestation letters. You can't govern what you can't see.

2



Tier by risk

Adopt a simple classification so low-risk tools move fast and high-risk tools get real scrutiny.

3



Convene the right table

Multidisciplinary from day one, and at an AMC, include an education voice.

4



Borrow, then adapt

Map to national standards, learn from Duke, Stanford, and Mayo, then add what makes your institution distinct.

References

- American Hospital Association IT Supplement / ASTP Data Brief. Hospital Trends in the Use, Evaluation, and Governance of Predictive AI, 2023–2024.
- IBM. Cost of a Data Breach Report 2025. July 2025.
- Black Book Research. Hospital AI Governance survey (n=182), Oct–Nov 2025.
- Joint Commission & Coalition for Health AI. Responsible Use of AI in Healthcare (RUAIH). Sept 17, 2025.
- NIST. AI Risk Management Framework 1.0 (AI 100-1), Jan 2023; Generative AI Profile (AI 600-1), July 2024.
- HHS. Artificial Intelligence Strategy. Sept 30, 2025.
- OMB. M-25-21 and M-25-22. April 2025.
- FDA. AI/ML-Based Software as a Medical Device guidance; Good Machine Learning Practice; PCCP guidance.
- Coalition for Health AI. Applied Model Card schema.
- Duke Health AI Evaluation & Governance Program. ABCDS Oversight.
- Stanford Medicine & Stanford HAI. RAISE-Health initiative.
- Mayo Clinic. A Comprehensive Approach to Responsible AI Development and Deployment. Mayo Clin Proc Digit Health, 2025.
- ONC HTI-1 Final Rule, Dec 2023; HHS OCR Section 1557 Final Rule, May 2024; EU AI Act, Aug 2024.
- Ke Y, Jin L, Ong JCL, et al. AI-induced never-skilling in medical education. Nat Med 2026;32(6):1997-2006.
- Budzyn K, et al. Endoscopist deskilling risk after exposure to AI in colonoscopy. Lancet Gastroenterol Hepatol 2025;10(10):896-903.